23.1 Introducing authentication and authorization

When you add sign-in functionality to your app and control access to certain functions based on the currently signed-in user, you're using two distinct aspects of security:

- *Authentication*—The process of determining who you are
- *Authorization*—The process of determining what you're allowed to do

Generally you need to know *who* the user is before you can determine *what* they're allowed to do, so authentication always comes first, followed by authorization. In this chapter we're looking only at authentication; we'll cover authorization in chapter 24.

In this section I start by discussing how ASP.NET Core thinks about users, and I cover some of the terminology and concepts that are central to authentication. I found this to be the hardest part to grasp when *I* learned about authentication, so I'll take it slow.

Next, we'll look at what it means to sign in to a traditional web app. After all, you only provide your password and sign into an app on a single page; how does the app know the request came from you for subsequent requests?

23.1.1 Understanding users and claims in ASP.NET Core

The concept of a user is baked into ASP.NET Core. In chapter 3 you learned that the HTTP server, Kestrel, creates an `HttpContext` object for every request it receives. This object is responsible for storing all the details related to that request, such as the request URL, any headers sent, and the body of the request.